

Pille Lehis
Andmekaitse Inspeksioon
Tatari 39, 10134 Tallinn
info@aki.ee

MÄRGUKIRI

07.04.2026

Lugupeetud Andmekaitse Inspeksiooni peadirektor

Käesoleva märgukirjaga juhime Andmekaitse Inspeksiooni (edaspidi Inspeksioon) tähelepanu tõsistele puudujääkidele SK ID Solutions AS-i (edaspidi SK) pakutava Smart-ID teenuse andmetöötluse turvameetmetes. Avalikult kättesaadava tehnilise dokumentatsiooni ja valdkondlike turvauuringute pinnalt on tekkinud põhjendatud kahtlus, et SK rikub isikuandmete kaitse üldmääruse (IKÜM) artiklitest 24, 25 ja 32 tulenevaid nõudeid, rakendades teadlikult vastutuse hajutamise strateegiat ning jättes kõrge riskiga isikuandmed tehnika tasemele vastava kaitseta.

1. Faktilised asjaolud ja tehnilised puudujäägid

SK pakub Smart-ID teenust, mis on eIDAS määruse kohaselt kvalifitseeritud usaldusteenus. Selle käigus töödeldakse miljonite Eesti elanike kriitilisi isikuandmeid (identifitseerimisandmed, autentimissessioonid, allkirjastamisandmed).

SK poolt avaldatud ametlikus tehnilises dokumentatsioonis (Smart-ID RP API v3, kättesaadav docs.smart-id.com) on välja toodud järgmised asjaolud:

Teavitusepõhine autentimisvoog (dokumentatsioonis Notification based flow) on märgitud kui ebasoovitav lahendus.

SK tunnistab otse, et antud autentimisviisi puhul sõltub kaitse õngitsusrünnete (sh phishing) eest "kasutaja teadlikkusest".

Samas dokumentatsioonis on välja toodud turvalisemad seadmesisese lingi vood (Device link flows), mis pakuvad maksimaalset tehnilist kaitset õngitsusrünnete vastu.

Vaatamata tehnika tasemele vastavate turvaliste alternatiivide olemasolule ei ole need teenuse integratsioonides muudetud vaikumisi nõutavaks ega kohustuslikuks.

Selline arhitektuuriline ülesehitus avab ukse QR-koodi seansikaaperdusele (QR Code Session Jacking ehk

QRLJacking) ja vahendajarünnete (MitM). Ründajal on võimalik ebakindlat teavitusepõhist voogu ära kasutades detekteerida kasutaja autentimissessioon, pääseda ligi isikuandmetele ning sooritada kasutaja nimel lubamatuid toiminguid.

2. Õiguslik hinnang ja viited võimalikele rikkumistele

2.1. Töötlemise turvalisus (IKÜM artikkel 32)

IKÜM artikkel 32 lõige 1 kohustab vastutavat töötlejat rakendama asjakohaseid tehnilisi ja korralduslikke meetmeid, võttes arvesse tehnika taset (state of the art) ja andmesubjektide õigusi ohustavaid riske. QRLJacking ja MitM on kaasaegses küberturvalisuses tuntud ohud, mille vastu eksisteerivad tehnika tasemele vastavad lahendused (nagu SK ise on oma seadmesisese lingi voogudega tõestanud). Jättes need meetmed rakendamata väidetava "integratsiooni keerukuse" tõttu ning delegerides turvalisuse kasutaja teadlikkusele, eirab SK selgelt tehnika taseme nõuet isikuandmete turvalisusel. Isikuandmete pealtkuulamist ja vaheltlõikamist võimaldava süsteemi teadlik töös hoidmine on vastuolus määruse nõuetega.

2.2. Lõimitud ja vaikumisi andmekaitse (IKÜM artikkel 25)

Artikkel 25 nõuab, et andmekaitsemeetmed (sh infoturve) peavad olema süsteemi arhitektuuri integreeritud (lõimitud) ja süsteem peab pakkuma vaikumisi kõrgeimat andmekaitse taset. Asjaolu, et Smart-ID süsteem võimaldab e-teenuste pakkujatel vaikumisi kasutada ebakindlamat, kasutaja tähelepanule tuginevat autentimisviisi, rikub vaikumisi andmekaitse põhimõtet. "Kasutaja teadlikkus" ei vasta IKÜM artiklis 25 nõutud tehnilise ega korraldusliku meetme definitsioonile andmekaitse süsteemsel kujundamisel.

2.3. Vastutava töötleja vastutus (IKÜM artikkel 24)

SK on usaldusteenuse pakkujana identiteediandmete töötlemisel vastutav töötleja. Dokumentatsioonist nähtub, et SK on riske teadvustanud (dokumenteeritud "ebasoovitav" märke API-s), kuid lükanud riski maandamise vastutuse teenusepakkujatele (API integreerijatele) ja lõppkasutajatele. IKÜM artikli 24 kohaselt on aga just vastutaval töötlejal kohustus tagada määrusega kooskõlas olev andmetöötlus. Teadaoleva ja kõrge riski aktsepteerimine ning selle hajutamine ei ole õiguspärane, eriti arvestades töödeldavate isikuandmete kriitilisust. Euroopa varasem praktika (sh Belgia Itsme ja Põhjamaade BankID juhtumid) kinnitab, et sarnaste haavatavuste puhul eeldatakse usaldusteenuse pakkujalt tehnilise taseme viivitamatut tõstmist.

3. Taotlus ja ettepanekud Inspeksioonile

Eelnevale tuginedes palume Andmekaitse Inspeksioonil:

Alustada riiklikku järelevalvemenetlust SK ID Solutions AS-i tegevuse suhtes hindamaks Smart-ID teenuse arhitektuuri vastavust IKÜM artiklites 24, 25 ja 32 sätestatud nõuetele.

Nõuda vastutavalt töötlejalt (SK) ametlikke selgitusi selle kohta, miks on jäetud tehnika tasemele vastavad turvameetmed (QRLJacking ja MitM rünnete vältimiseks) vaikumisi rakendamata, olgugi et ohud on nende endi dokumentatsioonis tuvastatud.

Teha järelevalvemenetluse tulemusel ettekirjutus, mis kohustaks SK-d seadistama süsteemid vastavusse lõimitud ja vaikumisi andmekaitse põhimõtetega (nt muutes seadmesisese lingi vood või nendega samaväärse turvasemega lahendused vaikumisi standardiks ning piirates ebakindlate voogude kasutamist).

Kaaluda haldustrahvi kohaldamist vastavalt IKÜM artiklile 83, võttes arvesse isikuandmete kategooriaid, puudutatud andmesubjektide hulka ning tõendeid, mis viitavad riskide teadlikule eiramisele.

Teha järelevalve läbiviimisel koostööd Riigi Infosüsteemi Ametiga (RIA), kes teostab järelevalvet usaldusteenuste turvanõuete üle e-identimise ja e-tehingute usaldusteenuste seaduse (EUTS) alusel.

Oleme valmis esitama täiendavaid selgitusi ja viiteid tehnilistele uuringutele, mis kinnitavad käesolevas märgukirjas esitatud asjaolusid.

Palun vastata mulle kirjalikult e-postiga.

Lugupidamisega

(allkirjastatud digitaalselt)

Tom Kristian Abel
Märgukirja esitaja

Lisad:
